PayNest Technologies Private Limited

Contracting Standards

A simple guide for reviewing client contracts

Issued by the Compliance Team | Version 1.0

Why you have this

Clients often send us their own contract to sign. PayNest is the **Service Provider**, and the client wrote the words, so read every clause by asking: **what is the risk to PayNest?** Check each clause against the 10 standards in this guide. Each one tells you what we want, what we can accept, and what we must never accept.

What each result means

Result	Meaning	Risk points
OK	Matches what we want.	0
Not mentioned (fine)	The contract is silent, and silence is safe for this standard.	0
Acceptable	Not ideal, but inside what we can accept. Needs the named approver.	Half the weight
Not acceptable	Falls in Never accept. We must negotiate, or senior people must decide.	Full weight
Missing	The contract is silent, and silence is a risk for this standard.	Full weight
Doesn't apply	Only for special cases, such as a pilot with no live employee data.	Not counted

How the risk score works

Risk score = risk points / total weights of the standards counted x 100. All 10 weights add up to 35.

0 to 20	21 to 45	46 to 70	71 to 100
Low	Medium	High	Critical

Safety rule: if a **key rule** (P1, P2 or P3) is Not acceptable or Missing, the contract is at least **High**, whatever the score says.

The 10 standards

No.	Standard	Weight	The question to ask
P1	Limitation of Liability *	5	What is the most PayNest could owe?
P2	Indemnification *	5	Whose fault must it be before PayNest pays?
P3	Security Incident Notification *	5	How fast must PayNest report a data leak?
P4	Service Levels and Service Credits	4	How much uptime, and what if we miss it?
P5	Audit and Inspection Rights	3	How often, and with how much notice?
P6	Return and Deletion of Client Data	3	How long do we have when the contract ends?
P7	Confidentiality	4	Do both sides protect secrets? Must we share ours?
P8	Fees, Invoicing and Payment	2	How long can the client take to pay?
P9	Term and Termination	2	How much notice before the client can leave?
P10	Governing Law and Dispute Resolution	2	Whose law, and which city or country?

* Key rule

P1 Limitation of Liability

KEY RULE | Weight 5

In simple words: The most money PayNest can be asked to pay if something goes wrong. Think of it as a ceiling. If a client pays INR 10 lakh a month, a 12-month cap means PayNest can never owe more than INR 1.2 crore.

WHAT WE WANT

- Cap of **12 months' fees**, for both sides
- No claims for indirect loss or lost profit
- Fraud, wilful misconduct, and death or injury caused by negligence stay outside the cap

Example: *Each Party's total liability will not exceed the Fees of the last 12 months.*

WE CAN ACCEPT

- A higher cap of **up to 24 months' fees**, only for data protection and confidentiality breaches
- The general cap stays at 12 months

Example: *Liability is capped at 12 months' Fees, or 18 months' Fees for a data protection breach.*

NEVER ACCEPT

- **No cap at all**, generally or for data breach
- Any cap above 24 months' fees
- Removing the indirect loss exclusion
- Paying lost profit of the client's customers or staff

Example: *The Service Provider is liable for all losses without limit.*

If the contract says nothing: Missing: we need a cap in writing.

Who approves: We can accept: Legal Counsel. Never accept: General Counsel and CFO.

P2 Indemnification

KEY RULE | Weight 5

In simple words: A promise to cover the other side's costs if an outsider sues them because of your mistake. If a client's own attendance file was wrong and staff sue, PayNest should not pay for that.

WHAT WE WANT

- **Both sides** give the promise
- Only third-party claims
- Only when caused by that side's own breach, negligence or wilful misconduct
- Stays under the liability cap

Example: *Each Party will indemnify the other for third-party claims to the extent caused by its own breach.*

WE CAN ACCEPT

- A one-way promise from PayNest, only for named claims: IP infringement, or a data breach caused by PayNest's own security failure
- Capped at the higher data cap

Example: *PayNest will indemnify the Client for third-party IP claims, up to the agreed cap.*

NEVER ACCEPT

- **"Any and all claims"**, whoever was at fault
- No cap on the indemnity
- Covering the client's own negligence, instructions or data
- Paying the client's regulatory fines

Example: *The Provider will indemnify the Client against any and all claims regardless of fault.*

If the contract says nothing: Fine: no clause means no extra promise beyond the general law.

Who approves: We can accept: Legal Counsel. Never accept: General Counsel.

P3 Security Incident Notification

KEY RULE | Weight 5

In simple words: How fast PayNest must tell the client about a data leak. PayNest first needs time to confirm what happened. A very short or vague deadline puts PayNest in breach while it is still investigating.

WHAT WE WANT

- Notice **within 24 hours of confirming** the incident
- A written report within 72 hours

Example: *PayNest will notify the Client within 24 hours of confirming a Security Incident.*

WE CAN ACCEPT

- A window of **12 to under 24 hours** from confirming
- Or 24 hours from discovery, not confirmation

Example: *PayNest will notify the Client within 18 hours of confirming a Security Incident.*

NEVER ACCEPT

- **"Immediately"**, "forthwith" or any vague deadline
- Any window **under 12 hours**
- PayNest having to tell the client's staff or regulators directly

Example: *The Provider will notify the Client within 4 hours of any incident.*

If the contract says nothing: Fine: our Incident Response Policy (24 hours) applies.

Who approves: We can accept: Legal Counsel with CISO. Never accept: General Counsel.

P4 Service Levels and Service Credits

Weight 4

In simple words: How often our system must be up, and what the client gets if it is not. 99.5% in a 30-day month allows about 3.6 hours of unplanned downtime. A service credit is a discount on that month's fees.

WHAT WE WANT

- **99.5%** each month, not counting maintenance announced 72 hours ahead
- Credits capped at **10%** of monthly fees
- Credits are the client's **only** remedy

Example: *Availability is 99.5% monthly. Credits are the Client's sole and exclusive remedy.*

WE CAN ACCEPT

- Availability up to **99.9%**
- Or a credit cap up to **20%**
- Credits must stay the only remedy

Example: *Availability is 99.9% monthly, with credits as the sole remedy.*

NEVER ACCEPT

- Availability **above 99.9%**
- Uncapped penalties
- Credits plus damages plus the right to exit after one failure
- Penalties for errors caused by the client's data or late approvals

Example: *Availability is 99.99%, and credits are in addition to damages.*

If the contract says nothing: Fine: our published targets apply.

Who approves: We can accept: Legal Counsel. Never accept: General Counsel and Head of Service Delivery.

P5 Audit and Inspection Rights

Weight 3

In simple words: When the client may come and check our work. Our data centres also hold other clients' data, so visits must be limited and planned.

WHAT WE WANT

- **Once** in 12 months
- **30 days'** written notice, in business hours, at the client's cost
- Auditor keeps it confidential and is not a competitor
- Or we give our ISO 27001 certificate and audit report instead

Example: *The Client may audit once in any 12 months on 30 days' written notice.*

WE CAN ACCEPT

- Up to **2 audits** in 12 months
- Or notice of **at least 15 days**
- All other conditions stay

Example: *The Client may audit once a year on 20 days' written notice.*

NEVER ACCEPT

- Unannounced or "any time" audits
- Unlimited audits
- Notice under 15 days
- An auditor who is our competitor
- Access to other clients' data

Example: *The Client may enter the Provider's premises unannounced.*

If the contract says nothing: Fine: no clause means no audit duty.

Who approves: We can accept: Legal Counsel. Never accept: General Counsel and CISO.

P6 Return and Deletion of Client Data

Weight 3

In simple words: What happens to the client's data when the contract ends. Backups are cleared on a fixed cycle, so a very short deadline cannot be met safely.

WHAT WE WANT

- Return and delete **within 30 days**, in a standard format
- Backups cleared in the next scheduled rotation
- Deletion certificate on written request
- Legally required records may be kept

Example: *Within 30 days the Provider will return Client Data and delete it from live systems.*

WE CAN ACCEPT

- Return and delete within **8 to 29 days**
- The backup rotation stays

Example: *Within 15 days the Provider will return and delete Client Data.*

NEVER ACCEPT

- **7 days or less**, or "immediately"
- Immediate deletion from all backups
- Client having direct access to our databases or backups

Example: *The Provider will delete all data, including backups, within 3 days.*

If the contract says nothing: Fine: our Data Retention Policy (30 days) applies.

Who approves: We can accept: Legal Counsel. Never accept: General Counsel and CISO.

P7 Confidentiality

Weight 4

In simple words: Both sides keep each other's secrets. For PayNest this covers our prices, system design and security documents. We promise every client that its data is never shared with others.

WHAT WE WANT

- Applies to **both sides**
- Covers prices, system design and security documents
- Usual exceptions: public, independently developed, lawfully received, or required by law
- Lasts **at least 3 years** after the end

Example: *Each Party will keep the other's Confidential Information secret for 3 years after the end.*

WE CAN ACCEPT

- One-way protection for the client only, if a separate NDA protects our security documents

Example: *The Provider will protect Client information. A separate NDA covers PayNest's security documents.*

NEVER ACCEPT

- Having to give client data, staff data, security assessments or audit reports to **other vendors or third parties**
- A client right to publish or pass on our security reports

Example: *The Client may publish the Provider's security reports on its website.*

If the contract says nothing: Missing: our prices and security documents would be unprotected.

Who approves: We can accept: Legal Counsel. Never accept: General Counsel.

P8 Fees, Invoicing and Payment

Weight 2

In simple words: When the client must pay us. PayNest runs payroll on fixed dates whether or not the client has paid, so we should not act as the client's bank.

WHAT WE WANT

- Invoice monthly, in advance
- Pay **within 30 days** of the invoice date
- Interest on late payment
- We may suspend if undisputed fees are unpaid 60 days after the due date

Example: *The Client will pay each invoice within 30 days of the invoice date.*

WE CAN ACCEPT

- Pay within **31 to 60 days**
- The suspension right stays

Example: *The Client will pay each invoice within 50 days of the invoice date.*

NEVER ACCEPT

- Pay **later than 60 days**
- Payment only if the client is satisfied
- A right to hold back payment with no end date

Example: *The Client will pay within 90 days, subject to its satisfaction.*

If the contract says nothing: Missing: no due date means no way to enforce payment.

Who approves: We can accept: Legal Counsel. Never accept: CFO.

P9 Term and Termination

Weight 2

In simple words: How each side can leave. Setting up a new client takes months of work, so a very quick exit means PayNest may never recover that effort.

WHAT WE WANT

- Client may leave on **90 days' notice**
- Either side may leave after a serious breach not fixed in 30 days
- No refund for work already done
- We may suspend or end if the client keeps not paying

Example: *The Client may terminate on 90 days' written notice.*

WE CAN ACCEPT

- Client may leave on **30 to 89 days'** notice
- All other conditions stay

Example: *The Client may terminate on 45 days' written notice.*

NEVER ACCEPT

- Notice **under 30 days**
- Refund of fees for work already done
- PayNest having no right to suspend or end for non-payment

Example: *The Client may terminate on 15 days' notice and receive a full refund.*

If the contract says nothing: Missing: nothing would control how either side can leave.

Who approves: We can accept: Legal Counsel. Never accept: General Counsel.

P10 Governing Law and Dispute Resolution

Weight 2

In simple words: Which country's law applies, and where a fight would be heard. PayNest is based in Bengaluru, so distant courts cost us more money and management time.

WHAT WE WANT

- **Indian law**
- **Bengaluru** courts
- Or arbitration in Bengaluru under the 1996 Act, one arbitrator, in English

Example: *The laws of India apply, and the courts at Bengaluru have exclusive jurisdiction.*

WE CAN ACCEPT

- Indian law, with courts or arbitration **elsewhere in India**

Example: *The laws of India apply, and the courts at New Delhi have jurisdiction.*

NEVER ACCEPT

- **Any foreign law**
- A foreign court or arbitration seat

Example: *The laws of England apply, and the courts of London have jurisdiction.*

If the contract says nothing: Missing: law and venue would be open to dispute.

Who approves: We can accept: Legal Counsel. Never accept: General Counsel.